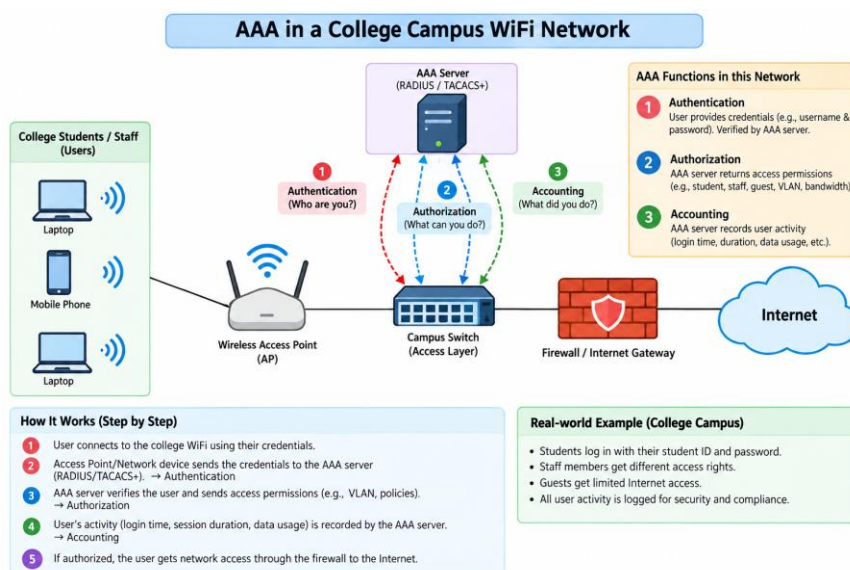


Tasks'

1. Create a table comparing Authentication, Authorization, and Accounting (AAA) by listing at least two real-world examples of each function from popular apps like Instagram, Zomato, or Paytm.

AAA Function	Meaning	Real-world Example 1	Real-world Example 2
Authentication	Verifies who you are.	Instagram: You enter your username/password or OTP to log in.	Paytm: You verify your mobile number using an OTP to access your account.
Authorization	Determines what you are allowed to do after logging in.	Instagram: A normal user can create posts, but only authorized account owners can change account settings.	Zomato: A customer can place an order, while a restaurant partner can manage its menu and incoming orders.
Accounting	Records what you did, such as activity, transactions, or usage.	Paytm: Records details of payments and transactions made from your account.	Zomato: Records your orders, payment history, and order activity.

2. Draw a simple network diagram showing how AAA is used to secure access to a WiFi network in a college campus, labeling where authentication, authorization, and



accounting take place.

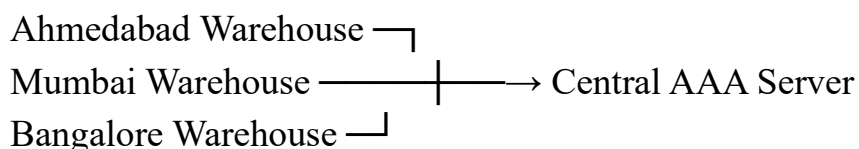
Hint: Include devices like user laptops, access points, AAA server, and the internet gateway.

3. Explain the difference between centralized and distributed AAA deployment models by describing how each would work in a scenario where multiple Flipkart warehouses need secure network access.

Point	Centralized AAA	Distributed AAA
AAA Server Location	One or a few AAA servers are located at a central data center/cloud.	Each warehouse has its own local AAA server or authentication service.
Authentication	Ahmedabad, Mumbai, and Bangalore warehouses send authentication requests to the central AAA server.	Each warehouse can authenticate its users locally.
Management	User accounts and security policies can be managed from one central location.	Each warehouse may manage its own local users and policies.
Internet/WAN Dependency	A WAN connection to the central AAA server is normally required for authentication.	Local authentication can continue even if the WAN connection to another location is unavailable.
Example	An employee in the Ahmedabad warehouse logs in → request travels to the central AAA server → credentials are verified → access is granted.	An employee in Ahmedabad logs in → the local AAA server verifies the credentials → access is granted locally.

1. Centralized AAA

Flow:



For example, when a Flipkart employee in Mumbai connects to the warehouse Wi-Fi, the access point/network device sends the authentication request to the central AAA server. The central server verifies the employee and returns the appropriate access permissions.

Main idea: One central system controls authentication, authorization, and accounting for all warehouses. 2. Distributed AAA

Flow:

Ahmedabad → Local AAA Server

Mumbai → Local AAA Server

Bangalore → Local AAA Server

For example, an employee in the Bangalore warehouse connects to Wi-Fi. The request is handled by the Bangalore local AAA server, without needing to contact a central AAA server for every authentication.

Main idea: AAA services are placed closer to each warehouse and can operate more independently.

4. Pick any one AAA deployment model and list three advantages and two disadvantages of using it for a large-scale app like BookMyShow.

Advantage:

Advantage	Explanation	BookMyShow Example
1. Centralized Management	User authentication and access policies can be managed from one place.	BookMyShow can centrally manage millions of user accounts and their access permissions.
2. Consistent Security	The same security policies can be applied across different services and locations.	Login, administrator access, and API access can follow consistent authentication and authorization policies.
3. Easier Monitoring & Accounting	User activities and authentication events can be collected centrally.	BookMyShow can track login attempts, session activity, and other security events to help detect suspicious activity.

Disadvantage:

Disadvantage	Explanation
1. Dependency on Central Service	If the central AAA service becomes unavailable and there is no redundancy/failover, authentication-related services could be affected.
2. Scalability & Performance Challenges	A very large number of authentication requests, such as during a major movie-ticket release, can create heavy load and require careful scaling.

5. Use ChatGPT or another AI tool to generate a sample AAA policy for a Zomato-like app, specifying what actions are authenticated, which roles are authorized for each action, and what accounting logs should be kept. Paste the generated policy and highlight one thing you would change to make it more secure.

Sample AAA Security Policy — Zomato-like Food Delivery App

1. Authentication — “Who are you?”

Action	Authentication Required
Customer login	Yes — password/OTP
Restaurant partner login	Yes — password + MFA
Delivery partner login	Yes — password/OTP
Place an order	Yes — authenticated customer
View order history	Yes
Make a payment	Yes — additional payment verification when required
Access admin dashboard	Yes — password + MFA

2. Authorization — “What are you allowed to do?”

Role	Authorized Actions
Customer	Browse restaurants, place orders, make payments, view/cancel eligible orders, view own order history
Restaurant Partner	Manage own restaurant menu, accept/reject orders, update order status, view own restaurant orders
Delivery Partner	View assigned deliveries, update delivery status, view necessary delivery information
Support Agent	View customer/order information required for support and update permitted support fields

Administrator	Manage users, restaurants, delivery partners, security policies, and system configuration
----------------------	--

Principle of least privilege: Each role should receive only the permissions required to perform its job.

3. Accounting — “What did you do?”

- **Successful and failed login attempts**
- **Logout and session events**
- **Password/OTP changes**
- **MFA events**
- **Order creation, cancellation, and status changes**
- **Payment attempts and transaction status**
- **Changes to restaurant menus**
- **Delivery-status updates**
- **Administrator actions**
- **Permission/role changes**
- **Suspicious or unusual access attempts**

Each important log should include information such as timestamp, user/account identifier, action, result (success/failure), source/device information where appropriate, and relevant transaction/request ID. Logs should be protected against unauthorized modification and retained according to the organization's security and legal requirements.

Security Improvement I Would Make

Require step-up MFA for high-risk administrative actions.

Even if an administrator is already logged in, changing user permissions, disabling security controls, or accessing highly sensitive information should require MFA/step-up verification again. This adds an extra security layer if an administrator's existing session or password is compromised.